



PHISHING EMAIL DETECTION & AWARENESS REPORT

Identifying, Classifying and Preventing Email-Based Threats

Future Interns — Cybersecurity Task 2 (2026)

1. Introduction

Phishing is one of the most widespread and damaging cyber threats that organisations face today. Unlike technical exploits that target software vulnerabilities, phishing attacks target people. Attackers craft convincing emails that trick recipients into clicking malicious links, downloading infected files, or handing over sensitive information such as passwords and one-time PINs.

What makes phishing so dangerous is how believable these emails can look. A well-crafted phishing email can closely mimic a bank notification, an internal IT message, or a delivery confirmation — and many users, without proper training, cannot tell the difference.

This report was put together to address that gap. The goal is to analyse real phishing email samples, break down the techniques attackers use, classify each email by risk level, and provide practical guidance that employees can actually apply. Security is not just a technical problem — it is a people problem, and awareness is the most effective defence.

This report is intended for educational and internal security awareness purposes. All email samples are drawn from publicly available phishing datasets and anonymised examples used in security training.

2. Understanding Phishing Attacks

2.1 How Phishing Works

A phishing attack starts with an email that appears to come from a trusted source — a bank, a cloud service provider, a colleague, or even a company executive. The email creates a reason for the recipient to act quickly, usually by clicking a link or opening an attachment. That link typically leads to a fake website designed to steal login credentials, or the attachment contains malware that installs itself silently.

The success of these attacks is not accidental. Attackers deliberately exploit human psychology, using emotions like fear, urgency, curiosity, and trust to bypass rational thinking. Understanding these psychological triggers is just as important as recognising technical indicators.

2.2 Common Types of Phishing

Type	How It Works	Common Target
Email Phishing	Mass emails impersonating well-known brands or services	General employees and customers
Spear Phishing	Targeted emails personalised with the victim's name or role	Finance staff, HR, managers
Whaling	Spear phishing aimed specifically at executives	CEOs, CFOs, board members
Smishing	The same deceptive tactics delivered via SMS instead of email	Mobile users, remote workers
Business Email Compromise	Impersonating a manager or supplier to authorise payments	Accounts payable teams
Clone Phishing	A copy of a legitimate past email with links or files swapped out	Anyone who received the original

2.3 Why People Fall For It

Phishing works because it exploits normal human behaviour rather than technical weaknesses. The four main psychological levers attackers pull are:

- Urgency — Messages like "your account will be closed in 24 hours" force fast, unthinking responses.
- Authority — Emails that appear to come from IT, management, or banks carry automatic trust.
- Fear — Threats of penalties, legal action, or data loss override careful judgement.
- Familiarity — Logos, colours, and language copied from real brands make fake emails look genuine.

3. How to Spot a Phishing Email

Phishing emails almost always contain at least one tell-tale sign. Experienced analysts look across four areas when reviewing a suspicious email:

3.1 Sender Address and Domain

The sender address is often the easiest place to spot a fake. Attackers use several tricks to make their address look legitimate at a glance:

Technique	Phishing Example	Legitimate Address
Character substitution	support@paypa1.com (digit 1 instead of l)	support@paypal.com
Lookalike domain	security@apple-id-verify.com	no-reply@apple.com
Display name spoofing	"PayPal Support" <attacker@gmail.com>	"PayPal" <service@paypal.com>
Subdomain trick	paypal.com.account-confirm.ru	paypal.com
Free email service	it-helpdesk@gmail.com	helpdesk@yourcompany.com

3.2 Email Content Red Flags

- Generic greetings such as "Dear User" or "Dear Customer" instead of your actual name.
- Spelling mistakes and poor grammar — professional organisations proofread their communications.
- Requests for passwords, PINs, OTPs, or personal details — legitimate services never ask for these via email.
- Mismatched branding — the logo looks slightly different, fonts are off, or the colours do not match.
- Unsolicited attachments, especially file types like .exe, .zip, .docm, or .xlsm.
- Threatening language designed to create panic — "permanent suspension," "legal action," "final warning."

3.3 Link and URL Indicators

Always hover your mouse over a link before clicking. The real web address appears at the bottom of your browser — if it does not match the expected site, do not click.

Red Flag	What It Looks Like
HTTP instead of HTTPS	http://bank-login.com — no security certificate; data can be intercepted
IP address as URL	http://192.168.10.1/verify — real sites use domain names, not raw IPs
Excessive subdomains	login.verify.paypal.security.fakeDomain.com — the real domain is "fakeDomain.com"
URL shortener used	bit.ly/xk3p9a — hides the actual destination completely
Domain typosquatting	arnazon.com, rnicrosoft.com — easy to miss at a glance

Wrong domain in link text	Link says "Click here for Microsoft" but leads to microsoft-helpdesk.xyz
---------------------------	--

4. Phishing Email Samples — Analysis and Classification

The following emails were collected from publicly available phishing datasets and security training resources. Each one has been analysed for indicators and assigned a risk classification. The first sample is the example provided as part of this task brief.

Classification scale: SAFE — no threat indicators present. SUSPICIOUS — one or two soft warning signs, worth verifying. PHISHING — confirmed malicious intent, do not interact.

Sample 1: Account Suspension Warning (Task Sample)

From:	security-team@secure-account-verify.com
To:	user@company.com
Subject:	⚠ Urgent: Your Account Will Be Locked
Body:	Dear User, We noticed suspicious activity on your account. To avoid account suspension, please verify your details immediately. 🔗 Verify Now: http://secure-account-verify[.]com Failure to verify within 24 hours will result in permanent account lock. Regards, Security Team
Link:	http://secure-account-verify[.]com

Indicator Found	Analysis	Risk Level
Suspicious sender domain	"secure-account-verify.com" is not a domain associated with any real service. It was registered specifically to impersonate a security authority.	Critical
Generic greeting	"Dear User" — any legitimate service that has your account details would address you by your actual name.	High
Urgency and fear language	"24 hours" deadline and threat of permanent lock are classic pressure tactics designed to stop you thinking clearly.	High
Malicious link	The link leads to the same suspicious domain as the sender. No legitimate service sends you to a third-party site to verify your account.	Critical
HTTP (no encryption)	The link uses HTTP, not HTTPS. Any details entered would be transmitted without encryption, visible to anyone intercepting the connection.	High

CLASSIFICATION: PHISHING — All four classic indicators are present. Do not click any links. Delete the email and report it to your IT or security team.

Sample 2: Microsoft 365 Password Expiry

From:	noreply@microsoft-365-helpdesk.com
-------	------------------------------------

Subject:	Action Required: Your Microsoft 365 password expires in 2 hours
Body:	Your Microsoft 365 password is about to expire. To keep the same password and avoid losing access to your files and emails, click the link below immediately. This cannot be undone after expiry.
Link:	https://microsoftonline-passwordreset.xyz/update

Key indicators identified:

- The sender domain is "microsoft-365-helpdesk.com" — not a Microsoft domain. Microsoft emails come from microsoft.com or microsoftonline.com only.
- The link leads to "microsoftonline-passwordreset.xyz" — the .xyz extension and the hyphenated structure are typical of domains registered for phishing.
- The two-hour deadline is designed to stop the recipient from checking with IT first.
- Microsoft does not notify users of password expiry via unsolicited email with an external reset link.

CLASSIFICATION: PHISHING — Spoofed Microsoft branding, lookalike domain, and extreme urgency. Report and delete.

Sample 3: CEO Payment Request (Business Email Compromise)

From:	"James Mahon CEO" <j.mahon@company-corp.net> (real domain: company.com)
Subject:	Confidential — Urgent Wire Transfer
Body:	Hi Sarah, I'm in a board meeting and can't take calls right now. I need you to process a payment of \$47,500 to a new vendor today. This is time-sensitive and confidential — please don't discuss it with anyone until the transfer is complete. I'll explain the full details later. Thanks, James

Key indicators identified:

- The display name shows the real CEO's name but the actual sending address uses "company-corp.net" — a lookalike domain, not the real company domain.
- The request for secrecy is a major red flag. Legitimate financial requests do not require employees to bypass normal approval channels or hide the transaction from colleagues.
- The unavailability excuse ("in a meeting, can't take calls") prevents the recipient from verifying by phone, which is exactly the intent.
- No invoice or supporting documentation is attached, which would be required for any legitimate payment.

CLASSIFICATION: PHISHING (BEC) — Classic Business Email Compromise pattern. Always verify financial requests by calling the requester directly on a known number.

Sample 4: HR Policy Document with Macro Attachment

From:	hr-updates@company-hr-portal.org
--------------	----------------------------------

Subject:	Important: Updated Remote Work Policy — Acknowledgement Required by Friday
Body:	Please find attached the updated remote work and data handling policy effective from next month. All employees are required to read and acknowledge the document by end of Friday. Contact HR if you have any questions.
Attachment:	RemoteWorkPolicy_2026.docm (macro-enabled Word document)

Key indicators identified:

- The sender domain "company-hr-portal.org" is external. Internal HR communications should always come from the company's own domain.
- The attachment is a .docm file — a macro-enabled Word document. Macros can execute code silently when the file is opened. Legitimate HR policies are sent as PDFs or plain .docx files.
- The Friday deadline creates mild urgency without being so extreme as to raise immediate suspicion — a more subtle pressure tactic.
- No manager is copied in, and there is no reference to a previous policy or internal document system.

CLASSIFICATION: SUSPICIOUS — External sender and macro-enabled attachment are significant red flags. Do not open the attachment. Confirm directly with HR using a known internal contact.

Sample 5: Bank Identity Verification Request

From:	verify@secure-bankofamerica-accounts.com
Subject:	Bank of America: Verify Your Identity to Prevent Account Closure
Body:	We have detected unusual sign-in activity on your account. To protect your funds, we require you to verify your identity by confirming your Social Security Number and account PIN using the link below. Failure to comply within 48 hours will result in a 90-day account freeze.
Link:	http://bankofamerica-secure-verify.com/confirm

Key indicators identified:

- No bank will ever ask for your PIN or Social Security Number via email. This is an absolute rule across all legitimate financial institutions.
- The sender domain is "secure-bankofamerica-accounts.com" — Bank of America's real domain is bankofamerica.com. The real domain is buried in the middle of a longer string to confuse a quick reader.
- The 48-hour freeze threat is a fear tactic. Real fraud alerts ask you to call the number on the back of your card or log in directly through the bank's app.

CLASSIFICATION: PHISHING — Requests credentials no bank would ever ask for by email. Spoofed domain. Do not click or respond. Call your bank directly using the number on your card.

Summary — Classification of All Samples

#	Email Type	Primary Indicators	Technique	Classification
1	Account Suspension Warning	Fake domain, generic greeting, urgency, HTTP link	Credential Harvest	PHISHING
2	Microsoft 365 Password Expiry	Lookalike domain, extreme urgency, fake Microsoft branding	Credential Harvest	PHISHING
3	CEO Wire Transfer Request	Spoofed display name, secrecy request, no documentation	BEC / Impersonation	PHISHING
4	HR Policy Document	External sender, macro-enabled .docm attachment	Malware Delivery	SUSPICIOUS
5	Bank Identity Verification	Requests PIN and SSN, lookalike domain, fear tactics	Credential Harvest	PHISHING

5. Email Header Analysis

Every email carries a hidden set of technical information in its headers that reveals where the message actually came from, which servers it passed through, and whether it has been authenticated. Most email clients hide this information by default, but it is available to anyone who wants to check — and it is one of the most reliable ways to confirm a phishing attempt.

5.1 What Email Headers Contain

Header Field	What It Tells You	Phishing Red Flag
Return-Path	The address where bounced emails go — often different from "From"	Differs from the visible sender address
Received	The chain of mail servers the email passed through	Servers in unexpected or foreign locations
X-Originating-IP	The IP address of the machine that originally sent the email	IP traces back to a VPN, proxy, or foreign host
DKIM-Signature	A digital signature proving the email was not altered in transit	Missing, invalid, or signed by a different domain
SPF Result	Whether the sending server is authorised to send for that domain	"SoftFail" or "Fail" means the server is not authorised
DMARC Result	The combined authentication result based on SPF and DKIM	"Fail" means the email did not pass authentication checks

5.2 SPF, DKIM, and DMARC Explained Simply

These three standards work together to verify that an email genuinely came from the domain it claims to represent:

- SPF (Sender Policy Framework) is like a guest list for a domain's email servers. If the email comes from a server not on the list, the check fails.
- DKIM (DomainKeys Identified Mail) is like a wax seal on a letter. It proves the message came from the stated sender and has not been tampered with on the way.
- DMARC (Domain-based Message Authentication) is the policy that tells receiving mail servers what to do if SPF or DKIM fails — such as sending it to spam or rejecting it outright.

To view email headers in Gmail: open the email, click the three-dot menu, select "Show original." In Outlook: open the email, go to File > Properties, and look in the Internet Headers box. You can then paste the headers into a free analysis tool such as MXToolbox or the Google Admin Toolbox to get a clear, formatted breakdown.

5.3 What a Failed Header Check Looks Like

In the account suspension phishing email analysed in Sample 1, a header check would reveal the following:

Check	Result	Meaning
SPF	FAIL	The sending server is not authorised to send on behalf of the domain claimed.
DKIM	NONE	No digital signature was added — the email cannot be verified as unaltered.
DMARC	FAIL	Email failed authentication. A properly configured mail server would reject or quarantine this message.
Originating IP	Foreign Host	IP resolves to a server with no association to the claimed sender domain.

6. Prevention and Awareness Guidelines

Knowing how to spot a phishing email is only useful if that knowledge is applied consistently. The guidelines below are written to be shared with any member of staff, regardless of their technical background.

6.1 The STOP — THINK — VERIFY Method

Step	What to Do	Ask Yourself
 STOP	Pause before you click, download, or reply to anything	Is this creating urgency or panic? Was I expecting this email?
 THINK	Check the sender address, the links, and the language carefully	Does the sender domain look exactly right? Does the link destination match?
 VERIFY	Confirm through a separate, trusted channel before acting	Can I call the sender directly? Can I go to the website myself without using the link?

6.2 Do's and Don'ts for All Staff

 DO	 DO NOT
Hover over links to check the real URL before clicking	Click links in unsolicited emails even if they look real
Type the website address directly into your browser when in doubt	Open attachments you were not expecting
Use multi-factor authentication on all accounts	Share your password, PIN, or OTP with anyone over email
Report suspicious emails to your IT or security team	Forward suspicious emails to colleagues to "warn" them
Call the sender on a known phone number to verify urgent requests	Assume an email is safe because it uses a familiar logo
Use a different, strong password for every account	Act on financial requests received only by email without verification

6.3 Recommended Technical Controls for Organisations

- Deploy an email security gateway that scans and filters messages before they reach user inboxes.
- Enforce SPF, DKIM, and DMARC records on all company domains to prevent your brand being spoofed.
- Enable multi-factor authentication across all business systems, especially email and cloud applications.
- Add an [EXTERNAL] banner to all emails arriving from outside the organisation so staff are automatically alerted.
- Run regular phishing simulation exercises and provide immediate, educational feedback to users who click.

- Maintain a clear and easy way for staff to report suspicious emails — a single click or dedicated email address.

7. What to Do If You Are Targeted

Even with training and awareness, phishing attacks occasionally succeed. What matters most when that happens is responding quickly and correctly. The steps below cover the three most common situations.

7.1 You Received a Phishing Email But Did Not Click Anything

- Do not forward the email to colleagues to warn them — this spreads the threat unnecessarily.
- Report the email to your IT or security team using the reporting method your organisation has set up.
- Delete the email and empty your trash folder.

7.2 You Clicked a Link in a Phishing Email

- Disconnect your device from the network immediately — unplug the ethernet cable or turn off Wi-Fi.
- Do not try to fix the issue yourself. Contact your IT security team straight away and let them know what happened.
- Make a note of the time, the email subject, and exactly what you clicked — this information will help with the investigation.
- If the page asked you to log in, assume your credentials are compromised and follow the steps in section 7.3 below.

7.3 You Entered Your Credentials or Personal Details

- Change the compromised password immediately from a different, clean device.
- Change that password on any other account where you have used the same one.
- Enable multi-factor authentication on the affected account if it is not already active.
- Notify your IT security team and the affected service provider — for example, your bank, Microsoft, or Google.
- Monitor your accounts for any unusual activity over the following weeks.

Reporting a mistake quickly is the single most important action you can take. Security teams are there to help, not to blame. A fast report can limit the damage significantly and may prevent other colleagues from being affected by the same attack.

8. Conclusion

Phishing remains one of the most effective tools in an attacker's toolkit precisely because it does not rely on sophisticated technology — it relies on human nature. A well-timed, convincing email can bypass even the most robust technical defences if the person receiving it does not know what to look for.

The five email samples analysed in this report illustrate the range of approaches attackers use, from simple account suspension warnings to more complex Business Email Compromise schemes. Across all of them, the same core indicators appear: sender addresses that do not quite match, links that lead somewhere unexpected, a sense of urgency designed to rush the recipient into action, and requests for information or money that no legitimate organisation would make by email.

Awareness and education are not a one-time exercise. They need to be reinforced regularly through training, simulation exercises, and an organisational culture that makes it easy and safe for employees to question suspicious communications and report concerns without fear of judgement.

The goal of this report is not just to document phishing examples — it is to make the people who read it genuinely better equipped to protect themselves and the organisations they work for.

Samples Analysed	Confirmed Phishing	Suspicious	Safe / Legitimate
5	4	1	0